ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

VMware ESXi 8 (vSphere Hypervisor) · Component type: **Host Device (HDR) - bare-metal hypervisor** · Target SL = SL 3

Where to work	Verify by whichever access you have - all give the same result: **vSphere Client** (`https://<vcenter>/ui` → Hosts & Clusters › [host] › **Configure**), the **ESXi Host Client** (`https://<host>/ui`, the host's own web UI - no vCenter needed), **ESXCLI/PowerCLI**, and the **DCUI** console. Each row lists all paths.
Scope	ESXi 8 assessed as an **HDR (bare-metal hypervisor)** against the applicable 62443-3-3 SRs and 4-2 CRs + HDR requirements. Works vCenter-managed or standalone; vCenter/KMS-only controls (VM encryption, attestation, roles) are flagged per row so they can be marked N/A/Deferred + compensating where that access is not in scope.
Interfaces / ports	HTTPS **443** (Host Client / vSphere API); VMkernel **902**; **SSH 22** (off by default); DCUI (console); vMotion 8000; syslog 514; CIM 5989 (disable). Management VMkernel on its own isolated VLAN. Baseline against the DISA vSphere ESXi 8 STIG + vSphere Security Configuration Guide.
How to read	Each row = one SL-3 requirement with the path for **vSphere Client**, **Host Client**, and **CLI/PowerCLI** (use any). Default read-only - view settings and capture screenshots/exports. Mark **Pass / Fail / Partial / N/A / Deferred**; where Ignition-native isn't possible record Partial + compensating control + residual risk.

Evidence capture & handling - via vSphere Client (vCenter), ESXi Host Client, or CLI/PowerCLI

Do this BEFORE working the checklist. ESXi can be assessed several ways - use whichever access you have; the requirement is identical, only the click-path/command differs, and each row below gives all of them:

- **vSphere Client (vCenter)** `https://<vcenter>/ui` → Hosts & Clusters › [host] › **Configure** (plus Roles, VM Encryption, Key Providers, attestation that live only here).
- **ESXi Host Client** `https://<host>/ui` - the host's own web UI (no vCenter needed) under **Manage** / **Networking** / **Monitor**.
- **ESXCLI / PowerCLI** (`esxcli ...` / `Get-AdvancedSetting`) read the same values; **DCUI** at the console for banner / SSH / Secure Boot.

Capture as you go: (1) screenshot each config screen you verify (vSphere or Host Client) named to the requirement, e.g. `<site>_<assetTag>_ESXi_<host>_<SR#>_<YYYYMMDD>.png`; (2) download host logs - Host Client **Monitor › Logs** (auth.log/shell.log/hostd.log/vmkernel.log) or vCenter **Monitor › Export System Logs**; (3) take a host config backup (baseline; holds secrets) `Get-VMHostFirmware -BackupConfiguration` / `vim-cmd hostsvc/firmware/backup_config`; (4) record version + hardware/TPM (Help › About / Configure › Hardware) and photograph the DCUI banner; (5) if SSH is enabled, capture that session (PuTTY logging; pipe | `cat`) - SSH is off by default.

Protect + adjudicate: store all evidence **only** on the encrypted share (the .tgz backup holds secrets - never email in cleartext); mark each row **Pass / Fail / Partial / N/A / Deferred**. Rows that require **vCenter or a KMS** (VM encryption, attestation, roles) are labelled - mark **N/A / Deferred + compensating** only if that access is genuinely out of scope.

Screenshot capture list (Host Client path / vSphere Client path; one screenshot per screen, named with the SR# it evidences - where one screen evidences several rows, save it once and cite that file in each row; if you work by CLI, capture the same values as text in the logged session with `esxcli system settings advanced list -o <key>` / `Get-AdvancedSetting -Name <key>` instead):

- **Identity & build** (7.8, 3.5, 3.10) - **Help › About** + **Manage › Hardware** + **Manage › Packages** / [host] › Summary + Configure › Hardware.
- **Services** (1.1, 2.7, 2.13, 7.7) - **Manage › Services** (TSM, TSM-SSH, CIM state + policy) / Configure › System › Services.
- **Lockdown mode + exception users** (1.1, 1.4, 2.7) - **Manage › Security & users › Lockdown mode** / Configure › System › Security Profile › Lockdown Mode.
- **Users, roles, permissions** (1.3, 1.4, 2.1) - **Manage › Security & users › Users** and **› Roles** / Administration › Access Control › Roles + [host] › Permissions.
- **Acceptance level** (2.4, 3.2, 3.12) - **Manage › Security & users › Acceptance level** / Security Profile › Acceptance level.
- **Certificate** (1.8) - **Manage › Security & users › Certificates** / Configure › System › Certificate (issuer + validity visible).
- **Advanced settings, one per key** (filter by key) - **Manage › System › Advanced settings** / Configure › System › Advanced System Settings: `Security.PasswordQualityControl` (1.7), `Security.PasswordHistory` (1.5), `Security.AccountLockFailures` + `Security.AccountUnlockTime` (1.11), `UserVars.ESXiVPsDisabledProtocols` (1.9, 4.3), `UserVars.HostClientSessionTimeout`, `UserVars.ESXiShellInteractiveTimeOut`, `UserVars.ESXiShellTimeOut`, `UserVars.DcuiTimeOut` (2.5), `DCUI.Access` (2.13), `Annotations.WelcomeMessage` + `Config.Etc.issue` (1.12), `Syslog.global.logHost` + `Syslog.global.logDir` (2.8, 2.9), `VMkernel.Boot.execInstalledOnly` (2.4, 3.2, 3.4), `Config.HostAgent.plugins.solo.enableMob` (7.7).
- **Time** (2.11) - **Manage › System › Time & date** / Configure › System › Time Configuration.
- **Firewall rules with Allowed IP** (1.13, 5.2, 7.7) - **Networking › Firewall rules** / Configure › System › Firewall.
- **Networking** (1.2, 3.1, 5.1, 5.4) - **Networking › VMkernel NICs**, **Port groups**, **Virtual switches** (VLAN IDs) / Configure › Networking › VMkernel adapters + Virtual switches.
- **TPM / Secure Boot / attestation** (3.4, 3.11, 3.14) - **Manage › Hardware** / Configure › Hardware › Security + Monitor › Security (attestation - vCenter only).
- **Events / Tasks and logs** (2.8, 2.12, 6.1) - **Monitor › Events**, **› Tasks**, **› Logs** / [host] › Monitor › Events / Tasks.
- **Login page + DCUI** (1.10, 1.12) - the Host Client login page (masked password, banner) and a photo of the DCUI screen.
- **vCenter / KMS only, where in scope** (3.13, 4.1) - Key Providers, VM Options › Encryption, cluster encrypted vMotion, Trust Authority; otherwise record why they are N/A / Deferred.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.1	Human user I&A	All management authenticates; **SSH & ESXi Shell disabled**; **Lockdown Mode** on (vCenter-managed). **vSphere Client (vCenter):** Configure › System › **Services** (SSH/ESXi Shell Stopped) + **Security Profile** (Lockdown Mode). **Host Client:** **Manage › Services** (TSM / TSM-SSH Stopped, policy off) + **Manage › Security & users › Lockdown mode**. **CLI/PowerCLI:** `Get-VMHostService` / `esxcli system settings advanced list -o /UserVars/SuppressShellWarning`. **Test:** browse the UI logged-out → login required; SSH to the host → refused. **Ext. tools:** `nmap -p 22 <host>` (closed); DISA STIG/SCAP scan.	All host access authenticates; SSH/Shell off; Lockdown Mode on (N/A note if standalone).	HDR.
SR/CR 1.2	Software process / device I&A	Host has a unique managed identity; services/agents authenticate; single identified mgmt VMkernel; no anonymous API. **vSphere Client (vCenter):** [host] › Summary + Configure › Networking › VMkernel adapters. **Host Client:** **Networking › VMkernel NICs** + **Manage › Services**. **CLI/PowerCLI:** `Get-VMHost` / `esxcli network ip interface list`.	Host uniquely identified/managed; services authenticate; no anonymous API path.	
SR/CR 1.3	Account management	Minimal named accounts; root managed (vault/rotate); prefer AD/vCenter identity; no unused local accounts. **vSphere Client (vCenter):** [host] › Configure › System › **Security Profile** / Menu › Administration › SSO Users; join to AD via Authentication Services. **Host Client:** **Manage › Security & users › Users**. **CLI/PowerCLI:** `Get-VMHostAccount` / `esxcli system account list`.	Named least-priv identities; root managed; no unused local accounts.	
SR/CR 1.4	Identifier management	Unique user IDs, no shared root; Lockdown Exception Users minimized; unique host identity. **vSphere Client (vCenter):** Administration › SSO › Users and Groups; [host] › Configure › Security Profile › Lockdown Mode › Exception Users. **Host Client:** **Manage › Security & users › Users** + **Help › About** (host UUID/build). **CLI/PowerCLI:** `Get-VMHostAccount`.	Unique identifiers; shared root minimized; lifecycle via SSO/AD.	
SR/CR 1.5	Authenticator management	Password history set; root credential managed; host cert managed. **vSphere Client (vCenter):** Configure › System › **Advanced System Settings** → `Security.PasswordHistory`. **Host Client:** **Manage › System › Advanced settings** → `Security.PasswordHistory`. **CLI/PowerCLI:** `Get-AdvancedSetting -Name Security.PasswordHistory`.	Password history enforced; root credential managed/rotated.	
SR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password authentication	Strong local password policy. **vSphere Client (vCenter):** Configure › System › Advanced System Settings → `Security.PasswordQualityControl` (e.g. `retry=3 min=disabled,disabled,disabled,7,7`). **Host Client:** **Manage › System › Advanced settings** → same key. **CLI/PowerCLI:** `Get-AdvancedSetting -Name Security.PasswordQualityControl`. **Test:** set a weak local password → rejected.	Enforced length/complexity policy (visible in any path).	
SR/CR 1.8	PKI certificates	Host/mgmt certificate CA-signed (VMCA-subordinate or enterprise CA), valid, not default self-signed. **vSphere Client (vCenter):** [host] › Configure › System › **Certificate** (renew/import; issuer/validity). **Host Client:** **Manage › Security & users › Certificates** (or browser padlock → view cert). **CLI/PowerCLI:** `openssl s_client -connect <host>:443 | openssl x509 -noout -issuer -dates`.	CA-signed, in-date certificate; self-signed default replaced.	
SR/CR 1.9	Strength of public key-based auth	TLS 1.2/1.3 only, strong ciphers; strong SSH keys/ciphers if SSH used. **vSphere Client (vCenter):** Configure › System › Advanced System Settings → `UserVars.ESXiVPsDisabledProtocols` (TLS1.0/1.1 disabled). **Host Client:** same under **Manage › System › Advanced settings**. **CLI/PowerCLI:** `Get-AdvancedSetting -Name UserVars.ESXiVPsDisabledProtocols`. **Ext. tools:** `sslscan <host>:443` / `testssl.sh https://<host>`; ssh-audit (if SSH on).	Strong TLS only; weak protocols/ciphers disabled.	
SR/CR 1.10	Authenticator feedback	Password entry masked; pre-login banner leaks no host detail. **vSphere Client (vCenter):** / **Host Client:** login page masks the password field; **DCUI** at the console masks entry. Confirm `Annotations.WelcomeMessage` is a banner, not detail. **Ext. tools:** Visual (login page + DCUI photo).	Authenticators obscured at all login paths.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 1.11	Unsuccessful login attempts	Account lockout after N failures. **vSphere Client (vCenter):** Configure › System › Advanced System Settings → `Security.AccountLockFailures` (e.g. 3) + `Security.AccountUnlockTime` (e.g. 900). **Host Client:** same under **Manage › System › Advanced settings**. **CLI/PowerCLI:** `Get-AdvancedSetting -Name Security.Account*`. **Test:** (authorized) wrong password N times → lock; check auth.log.	Lockout threshold + unlock time set (any path shows it).	
SR/CR 1.12	System use notification	Approved banner at all login surfaces. **vSphere Client (vCenter):** / **Host Client:** Advanced settings → `Annotations.WelcomeMessage` (DCUI/UI) and `Config.Etc.issue` (shell/SSH); confirm the banner shows on the login page + DCUI. **CLI/PowerCLI:** `Get-AdvancedSetting -Name Annotations.WelcomeMessage`.	Approved banner set and displayed (UI + DCUI + shell).	
SR 1.13	Access via untrusted networks	Management on an isolated VLAN; host firewall restricts mgmt sources; Lockdown Mode; no direct mgmt from untrusted nets. **vSphere Client (vCenter):** Configure › Networking (VMkernel/mgmt VLAN) + Configure › System › **Firewall** (Allowed IP per service). **Host Client:** **Networking › VMkernel NICs** + **Networking › Firewall rules** (per-rule Allowed IP). **CLI/PowerCLI:** `esxcli network firewall ruleset allowedip list`. **Test:** from a non-mgmt VLAN reach `443/902` → must fail. **Ext. tools:** `nmap -p 443,902 <host>` by segment.	Mgmt reachable only from the isolated network (firewall + VLAN).	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 2.1	Authorization enforcement	Least-privilege roles/permissions; Exception Users minimal; DCUI.Access limited. **vSphere Client (vCenter):** Administration › Access Control › **Roles** + [host] › **Permissions** (assign least-priv roles); this is the full RBAC surface. **Host Client:** **Manage › Security & users › Roles** (local roles only on a standalone host). **CLI/PowerCLI:** `Get-VIPermission` / `Get-VIRole`. **Test:** low-priv user cannot change host config.	Least privilege enforced; exception users minimal (full RBAC = vCenter).	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable / mobile devices	Control removable/virtual media and datastore uploads. **vSphere Client (vCenter):** VM › Edit Settings (connected USB/CD/DVD) + Datastore permissions; Host USB passthrough. **Host Client:** VM › Edit settings (device list) + **Storage** datastore browser access. **CLI/PowerCLI:** PowerCLI VM device review.	No stray removable/virtual media; datastore upload restricted.	
SR/HDR 2.4	Mobile code	Only signed/installed binaries run. **vSphere Client (vCenter):** Configure › System › Advanced System Settings → `VMkernel.Boot.execInstalledOnly`=true + Security Profile › **Acceptance level** = Partner/VMware Certified. **Host Client:** **Advanced settings** (execInstalledOnly) + **Manage › Security & users › Acceptance level**. **CLI/PowerCLI:** `esxcli software acceptance get` / `Get-AdvancedSetting execInstalledOnly`.	execInstalledOnly on; acceptance level Partner+; no CommunitySupported.	HDR-specific.
SR/CR 2.5	Session lock / inactivity timeout	Idle timeouts on UI, shell and DCUI. **vSphere Client (vCenter):** / **Host Client:** Advanced settings → `UserVars.HostClientSessionTimeout`, `UserVars.ESXiShellInteractiveTimeOut`, `UserVars.ESXiShellTimeOut`, `UserVars.DcuiTimeOut` (all non-zero). **CLI/PowerCLI:** `Get-AdvancedSetting -Name UserVars.*TimeOut`.	UI + shell + DCUI idle timeouts set.	
SR/CR 2.6	Remote session termination	Idle sessions end; admins can terminate sessions. **vSphere Client (vCenter):** [host] › Monitor / vCenter session manager (terminate); timeouts as 2.5. **Host Client:** timeouts as 2.5; restart management agents to drop sessions. **CLI/PowerCLI:** `Get-AdvancedSetting *TimeOut`.	Sessions time out and are terminable.	
SR/CR 2.7	Concurrent session control	Direct sessions constrained. **vSphere Client (vCenter):** Configure › System › Security Profile › **Lockdown Mode** limits direct host sessions; SSH/Shell off. **Host Client:** **Manage › Services** (SSH/Shell off). **CLI/PowerCLI:** `Get-VMHostService`.	Direct sessions constrained (SSH/Shell off, lockdown where possible); residual noted.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 2.8	Auditable events	Remote syslog to SIEM; host events/audit captured. **vSphere Client (vCenter):** Configure › System › Advanced System Settings → `Syslog.global.logHost`; [host] › Monitor › **Events/Tasks**. **Host Client:** **Advanced settings** (logHost) + **Monitor › Logs / Events**. **CLI/PowerCLI:** `Get-AdvancedSetting -Name Syslog.global.logHost` / `esxcli system syslog config get`. **Test:** make a change → appears in Events and reaches the SIEM.	logHost set; events/audit records captured and forwarded.	
SR/CR 2.9	Audit storage capacity	Persistent logs + off-box forwarding survive reboot/local capacity. **vSphere Client (vCenter):** / **Host Client:** Advanced settings → `Syslog.global.logDir` / `logDirUnique` (persistent) + `Syslog.global.logHost`. **CLI/PowerCLI:** `esxcli system syslog config get`.	Persistent scratch/log dir + off-box forwarding configured.	
SR/CR 2.10	Response to audit processing failures	SIEM alerts on loss of forwarding; host keeps local logging. **vSphere Client (vCenter):** / **Host Client:** confirm `Syslog.global.logHost` set; coordinate a source-silent alert at the SIEM. **Ext. tools:** SIEM agent-health / syslog-gap alert.	Forwarding-loss alerting defined; local logging continues.	
SR/CR 2.11	Timestamps	NTP to authorized sources; service running. **vSphere Client (vCenter):** Configure › System › **Time Configuration** (NTP servers + service policy start/stop with host). **Host Client:** **Manage › System › Time & date** (NTP servers + Running). **CLI/PowerCLI:** `esxcli system ntp get` / `Get-VMHostNtpServer`. **Ext. tools:** Wireshark (NTP).	NTP configured to authorized servers + service running.	
SR/CR 2.12	Non-repudiation	Admin actions attributable to named users. **vSphere Client (vCenter):** [host] › Monitor › **Events / Tasks** (user per action). **Host Client:** **Monitor › Events / Tasks**; auth.log/shell.log in **Monitor › Logs**. **CLI/PowerCLI:** review shell.log / auth.log.	Events/Tasks attribute actions to named users.	
HDR 2.13	Use of physical diagnostic & test interfaces	Shell/SSH off; DCUI restricted; BMC/console controlled. **vSphere Client (vCenter):** Configure › System › Services (ESXi Shell/SSH off) + Security Profile; Advanced `DCUI.Access`. **Host Client:** **Manage › Services** (TSM/TSM-SSH off) + Advanced `DCUI.Access`. **CLI/PowerCLI:** `Get-VMHostService`; physical inspection of console/iLO/iDRAC.	Shell/SSH off; DCUI restricted; BMC/console physically controlled.	HDR-specific.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 3.1	Communication integrity	Mgmt on isolated VLAN, TLS everywhere, encrypted vMotion; no cleartext mgmt. **vSphere Client (vCenter):** Configure › Networking (mgmt VLAN) + Configure › System (advanced) + cluster **encrypted vMotion** (Required). **Host Client:** **Networking** (VMkernel/port groups); TLS on `/ui`. **CLI/PowerCLI:** PowerCLI vMotion-encryption; `esxcli network ip interface list`. **Ext. tools:** Wireshark on mgmt VLAN (TLS only).	Mgmt isolated + TLS-only; encrypted vMotion (vCenter) enabled.	
SR/HDR 3.2	Protection from malicious code	Only signed VIBs run. **vSphere Client (vCenter):** Security Profile › **Acceptance level** Partner/Certified + Advanced `VMkernel.Boot.execInstalledOnly`=true; Secure Boot (3.14). **Host Client:** **Manage › Security & users › Acceptance level** + Advanced settings. **CLI/PowerCLI:** `esxcli software acceptance get` / `esxcli software vib list`.	Only signed VIBs permitted; execInstalledOnly on; no CommunitySupported.	HDR-specific.
SR/CR 3.3	Security functionality verification	Re-verify hardening after change vs the vSphere SCG / DISA STIG. **vSphere Client (vCenter):** Host Profiles compliance (Policies and Profiles) or re-walk Configure screens. **Host Client:** re-check Advanced settings / Services / Firewall screens. **CLI/PowerCLI:** PowerCLI SCG/STIG audit script; compare to baseline .tgz.	Post-change re-verification matches the hardening baseline.	
SR/CR 3.4	Software & information integrity	Image + config integrity; TPM present; execInstalledOnly on; baseline backup. **vSphere Client (vCenter):** Configure › Hardware › **Security** (TPM/Secure Boot) + Advanced (execInstalledOnly). **Host Client:** **Manage › Hardware** (TPM) + Advanced settings. **CLI/PowerCLI:** `esxcli system settings encryption get` / `esxcli software vib signature verify`.	TPM present + execInstalledOnly on; config baseline (.tgz) captured; signed image.	
SR/CR 3.5	Input validation	Host patched against mgmt-API input-validation CVEs (VMware VMSA). **vSphere Client (vCenter):** [host] › Updates / Configure › About (build) + vLCM compliance. **Host Client:** **Help › About** / **Manage › Packages** (build). **CLI/PowerCLI:** `esxcli system version get`; cross-check VMSA. Do NOT fuzz production.	Current patched build; no known open input-validation CVE.	Do NOT fuzz production.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Coredump target set; no info leak; HA handles host failure. **vSphere Client (vCenter):** Configure › System (coredump/dump collector); cluster HA. **Host Client:** **Monitor › Logs** (no sensitive leakage). **CLI/PowerCLI:** `esxcli system coredump partition get` / `esxcli system coredump network get`.	Coredump target set; graceful failure; no info leak.	
SR/CR 3.8	Session integrity	Mgmt sessions TLS-protected, replay-resistant; bounded token life. **vSphere Client (vCenter):** / **Host Client:** TLS on the UI (padlock); session timeout (2.5). **CLI/PowerCLI:** Wireshark (TLS session); testssl.sh.	Mgmt sessions integrity-protected; bounded token lifetime.	
SR/CR 3.9	Protection of audit information	Logs forwarded to protected/immutable store; local tamper paths off. **vSphere Client (vCenter):** / **Host Client:** off-box syslog (2.8); SSH/Shell off; restrict datastore/log access. **CLI/PowerCLI:** SIEM immutability; log-permission review.	Audit records forwarded + protected from local tamper.	
HDR 3.10	Support for updates	Signed patches; rollback (prior boot bank). **vSphere Client (vCenter):** Lifecycle Manager (vLCM) baselines/images; [host] › Updates. **Host Client:** **Help › About** / **Manage › Packages** (build). **CLI/PowerCLI:** `esxcli software profile get`; keep prior boot bank.	Current signed build; rollback/prior boot bank available.	HDR-specific.
HDR 3.11	Physical tamper resistance/detection	TPM 2.0 + Secure Boot + attestation; chassis controlled. **vSphere Client (vCenter):** [host] › Monitor › **Security** (attestation, Trust Authority) + Configure › Hardware › Security. **Host Client:** **Manage › Hardware** (TPM); Secure Boot in BIOS/DCUI. **CLI/PowerCLI:** `esxcli system settings encryption get`; physical inspection.	TPM + Secure Boot on; attestation passes (vCenter); chassis controlled.	HDR-specific.
HDR 3.12	Provisioning product-supplier roots of trust	Only VMware-signed code boots/runs. **vSphere Client (vCenter):** attestation (Monitor › Security) + Acceptance level; Secure Boot validates signed bootloader/kernel/VIBs. **Host Client:** Acceptance level + Advanced execInstalledOnly. **CLI/PowerCLI:** `esxcli software vib signature verify`.	Supplier root of trust intact; only signed boot code/VIBs run.	HDR-specific.
HDR 3.13	Provisioning asset-owner roots of trust	Owner attestation + owner-managed keys. **vSphere Client (vCenter):** **vSphere Trust Authority** attestation cluster + **Key Providers** (owner KMS) - vCenter only. **Host Client:** not configurable in the Host Client. **CLI/PowerCLI:** Trust Authority / KMS review.	Owner attestation/KMS provisioned - **vCenter/KMS required**; N/A/Deferred + compensating if standalone.	HDR-specific; vCenter/KMS.
HDR 3.14	Integrity of the boot process	UEFI Secure Boot + TPM verify the signed boot chain. **vSphere Client (vCenter):** [host] › Monitor › Security (attestation) + Configure › Hardware › Security. **Host Client:** **Manage › Hardware** (TPM); Secure Boot in BIOS/DCUI. **CLI/PowerCLI:** `esxcli system settings encryption get` (Secure Boot / execInstalledOnly).	Secure Boot on + TPM present; signed-boot chain verified.	HDR-specific.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 4.1	Information confidentiality	Mgmt over TLS; VM encryption + encrypted vMotion where available. **vSphere Client (vCenter):** VM › VM Options › **Encryption** + vCenter › Configure › **Key Providers** (KMS); cluster encrypted vMotion Required - **vCenter/KMS only**. **Host Client:** Host Client cannot configure VM encryption - note limitation. **CLI/PowerCLI:** PowerCLI encryption mode.	Mgmt over TLS; VM/vMotion encryption where vCenter/KMS present (else N/A/Deferred + compensating).	vCenter/KMS for VM encryption.
SR/CR 4.2	Information persistence	Decommission wipes datastores/keys. **vSphere Client (vCenter):** destroy KMS keys (crypto-erase) + remove host/datastores. **Host Client:** **Storage › Datastores** (confirm no residual VM data). **CLI/PowerCLI:** KMS key destroy; datastore wipe verify.	No recoverable VM data/keys after decommission.	
SR/CR 4.3	Use of cryptography	TLS 1.2/1.3 + strong ciphers; legacy TLS off. **vSphere Client (vCenter):** / **Host Client:** Advanced settings → `UserVars.ESXiVPsDisabledProtocols` (TLS1.0/1.1 disabled). **CLI/PowerCLI:** `Get-AdvancedSetting -Name UserVars.ESXiVPsDisabledProtocols`. **Ext. tools:** `sslscan <host>:443` / `testssl.sh`.	TLS 1.2/1.3 + strong ciphers only; legacy TLS disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 5.1	Network segmentation	Separate VLANs for mgmt/vMotion/storage/VM traffic. **vSphere Client (vCenter):** Configure › Networking › **Virtual switches / Port groups / VMkernel adapters** (VLAN IDs). **Host Client:** **Networking › Port groups / VMkernel NICs**. **CLI/PowerCLI:** `Get-VirtualPortGroup` / `esxcli network vswitch standard portgroup list`. **Ext. tools:** Nmap across VLANs.	Mgmt/vMotion/storage/VM traffic on separate VLANs.	
SR 5.2	Zone boundary protection	Host firewall enabled, least services, per-service allowed IPs. **vSphere Client (vCenter):** Configure › System › **Firewall** (enabled; Allowed IP per service). **Host Client:** **Networking › Firewall rules** (enabled; per-rule Allowed IP). **CLI/PowerCLI:** `esxcli network firewall get` / `esxcli network firewall ruleset list`. **Test:** from outside the mgmt subnet reach 443/902 → blocked.	Firewall on with least services + allowed-IP restrictions.	
SR 5.3	General-purpose person-to-person comms restrictions	N/A - the bare-metal hypervisor runs no general-purpose person-to-person messaging; management is single-purpose. **vSphere Client (vCenter):** / **Host Client:** confirm no such services under Services.	N/A - single-purpose hypervisor; justification recorded.	N/A
SR 5.4	Application partitioning	Workloads isolated by VLAN/port group/resource pool (and cluster zoning for high assurance). **vSphere Client (vCenter):** Configure › Networking (port groups) + Resource Pools + cluster/host zoning. **Host Client:** **Networking › Port groups** + VM placement. **CLI/PowerCLI:** `Get-ResourcePool` / port-group review.	Workloads partitioned to contain compromise.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 6.1	Audit log accessibility	Logs viewable/exportable by authorized staff + SIEM copy. **vSphere Client (vCenter):** [host] › Monitor › **Export System Logs**. **Host Client:** **Monitor › Logs** (open/download auth.log, shell.log, hostd.log, vmkernel.log). **CLI/PowerCLI:** SIEM query.	Logs viewable/exportable (UI/vCenter) and in the SIEM.	
SR/CR 6.2	Continuous monitoring	Off-box forwarding + active monitoring/alerting. **vSphere Client (vCenter):** Advanced `Syslog.global.logHost` → SIEM; [host] › Monitor › **Alarms/Events**; Skyline health. **Host Client:** **Advanced settings** (logHost) + **Monitor › Events**. **CLI/PowerCLI:** syslog listener; SIEM alert check.	Logs forwarded + host/vCenter monitoring/alerting active.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR/CR 7.1	Denial of service protection	VM resource limits/shares/reservations + admission control so one VM cannot starve the host. **vSphere Client (vCenter):** VM › Edit Settings › **Resources** + cluster **Admission Control** (HA). **Host Client:** VM › Edit settings › Resources (limits/shares/reservations). **CLI/PowerCLI:** PowerCLI resource review.	VM resource controls set; host stays available under load.	
SR/CR 7.2	Resource management	Headroom monitored; no chronic saturation. **vSphere Client (vCenter):** [host] › Monitor › **Performance** (CPU/mem/datastore). **Host Client:** **Monitor › Performance** + Host summary gauges. **CLI/PowerCLI:** PowerCLI perf; vCenter charts.	Host CPU/mem/datastore within bounds; monitored.	
SR/CR 7.3	Control system backup	Host config backup + guest VM backups. **vSphere Client (vCenter):** VM backups via your backup tool (vSphere APIs); host profile export. **Host Client:** no config-backup button - use CLI. **CLI/PowerCLI:** `Get-VMHostFirmware -BackupConfiguration -DestinationPath .` / `vim-cmd hostsvc/firmware/backup_config` (download .tgz; `sha256sum` it).	Recent host config .tgz + guest VM backups captured and hashed.	
SR/CR 7.4	Control system recovery & reconstitution	Restore tested; RTO/RPO agreed. **vSphere Client (vCenter):** test a VM restore from backup; rebuild host from profile. **CLI/PowerCLI:** `Set-VMHostFirmware -Restore` / `vim-cmd hostsvc/firmware/restore_config` on a spare/lab host.	Host + VM restore tested; RTO/RPO met and documented.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Security settings documented, baselined, change-controlled. **vSphere Client (vCenter):** **Host Profiles** compliance (Policies and Profiles) captures/enforces the baseline. **Host Client:** baseline the Advanced settings / Services / Firewall / Users screens (screenshots) + the .tgz. **CLI/PowerCLI:** PowerCLI SCG/STIG audit; compare to baseline.	Settings documented/baselined (profile or screenshots + .tgz); change-controlled.	
SR/CR 7.7	Least functionality	Only required services; MOB/SSH/Shell/CIM off. **vSphere Client (vCenter):** Configure › System › Services (SSH/Shell/CIM off) + Advanced `Config.HostAgent.plugins.solo.enableMob`=false + Firewall (least services). **Host Client:** **Manage › Services** + Advanced (enableMob) + **Networking › Firewall rules**. **CLI/PowerCLI:** `Get-AdvancedSetting -Name Config.HostAgent.plugins.solo.enableMob`. **Ext. tools:** `nmap -sTU -p- <host>` (open services).	Only required services enabled; MOB/SSH/Shell/CIM off; lockdown where possible.	
SR/CR 7.8	Component inventory	Version/build/hardware/VIBs captured. **vSphere Client (vCenter):** [host] › Summary + Configure › Hardware. **Host Client:** **Help › About** / Host summary + **Manage › Hardware**. **CLI/PowerCLI:** `esxcli system version get`; `esxcli hardware platform get`; `esxcli software vib list`.	Complete version/build/hardware/VIB inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
vSphere Client (vCenter)	Full config + RBAC/encryption/attestation - many rows	Hosts & Clusters › [host] › **Configure** / **Monitor** / **Permissions**; Administration › Roles & SSO; Key Providers. The only place for roles, VM encryption, Trust Authority.	Authorized read account; screenshot screens.
ESXi Host Client (https://<host>/ui)	Direct host verification (no vCenter)	Manage › System / Services / Security & users; Networking › Firewall rules; Monitor › Logs/Events. Covers almost everything except vCenter-only RBAC/encryption/attestation.	Read-only review; screenshot each screen.
ESXCLI / PowerCLI	Cross-check any setting (all rows)	`Get-VMHost | Get-AdvancedSetting -Name Security.*`; `Get-VMHostService`, `Get-VMHostFirewallException`, `esxcli system syslog config get`, `esxcli software vib list`.	Read-only get; authorized account.
DCUI (physical console)	Banner, DCUI access, Secure Boot (1.10,1.12,2.13,3.11/3.14)	At the console confirm banner, restricted DCUI access, and BIOS/UEFI Secure Boot + boot order.	Physical access; photograph screens.
Host config backup (.tgz)	Baseline / backup (3.4, 7.3, 7.6)	`Get-VMHostFirmware -BackupConfiguration` / `vim-cmd hostsvc/firmware/backup_config` - the only full-config export.	Contains secrets - protect it.
DISA vSphere ESXi 8 STIG + vSphere Security Config Guide	Baseline compliance (all)	Evaluate against the STIG/SCG (STIG Viewer + PowerCLI audit); the primary pass/fail baseline the rows map to.	Authorized read-only audit.
sslscan / testssl.sh	TLS strength (1.9, 4.3)	`sslscan <host>:443`; confirm TLS1.2/1.3 + strong ciphers, no TLS1.0/1.1.	Read-only.
Nmap	Exposure & segmentation (1.1,1.13,5.x,7.7)	`nmap -sT -p 22,443,902,5989,8000 -T2 <host>` by segment; 22 closed, mgmt isolated.	Tune timing on production.
Syslog server / SIEM	Audit forwarding & monitoring (2.8,2.10,6.x)	Confirm host syslog + events arrive; trigger a test event; alert on forwarding loss.	Coordinate with SIEM team.
Nessus / OpenVAS	Known-CVE scan (3.5, general)	Authenticated scan for ESXi CVEs; cross-check VMware VMSA advisories.	ISOLATED/authorized.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.